Motion to update Tech Officer responsibilities

Raven Lucia (Proposer)[1], Mafi Illumina (Seconder)[2], and Finn McGoldrick (Thirder)[3]

[1]2110310
[2]5678455
[3]5532759

1 This Society Notes:

1. The Society's technical infrastructure hosts dozens of services, including both those relevant to the running of the society itself, and members' own created services.

2. There has been member concern regarding outages, changes (whether proposed or implemented) across the infrastructure, and security-related matters; additionally, transparency regarding each of these.

3. Security-related matters put an ever-growing challenge to maintenance on the infrastructure.

4. Until recently, most of the technical infrastructure's software was as much as 4 years out-of-date, which vastly increases exposure in an ever-evolving threat landscape.

5. Whilst, as a student space, the Society is not a professional nor corporate environment, there is a duty of care & responsibility over the membership that extends to the technical infrastructure.

6. The long-term operation of the technical infrastructure is additionally dependent on the satisfaction of three "stakeholder groups": the Society's membership, the Department of Computer Science (DCS), and the Information and Digital Group (IDG).

2 This Society Believes:

1. Tech Officers should have an explicit responsibility in the constitution for the security of the technical infrastructure. This includes (but not limited to) keeping services & other software up-to-date with regular frequency (can be largely automated with manual checks), auditing access to accounts, platforms & other services (including sufficient protection & backing up of member data, and time-limited retention of legacy data), and short turnarounds in vulnerability mitigation. This would align with best practice discussions with the DCS Tech team.

2. Tech Officers should responsibly disclose changes across the infrastructure, including advising of mitigations where this would not compromise the security of the infrastructure. Changes to services, including down-time, should be disclosed in a timely manner. Such disclosures should be accompanied with advice of best practice to members, and a clear point of contact & reporting. Where relevant, disclosures should also be proactively passed onto DCS Tech and/or IDG's Vulnerability Team and/or any other appropriate contacts.

3. Currently, it is not always necessarily possible, nor always in the best interest of members to rigidly stick to the 7 day notice period of maintenance, even if planned (e.g. see PHP incident recently or e.g. with DCS power cuts, the Society itself does not always receive 7 days notice but may still plan to safely bring the infrastructure down on (e.g.) 3 days notice). The security of the infrastructure must always be prioritised first, alongside the broad functioning of the infrastructure.

    - *For example, if there are major issues impeding members' access to Portainer generally, it doesn't strictly make sense to leave it broken for 7 days - this can also have significant impacts on the functioning of the Society as a whole.*

4. The 7 day notice of maintenance *should* be stuck to where reasonably possible, but flexibility on this can *only* be enabled by additional transparency expectations. Notices of unplanned maintenance and restoration of services should also reasonably be made.

3 This Society Resolves:

1. To amend "9.8.10 Technical Officer" in the constitution as follows:

    - After 9.8.10.a., add:
        - 9.8.10.b. The Technical Officer must proactively ensure the technical infrastructure of the Society is secured, including, but not limited to:
            * Regular updates, patches and migration across *all* services where possible, aiming for a weekly cadence, aided by utilisation of appropriate automations.
            * Enabling and frequent auditing of access across the whole infrastructure, with appropriate action to prevent unauthorised access or misuse.
            * Responsible timely disclosure of applied mitigations to members, and relevant teams such as DCS Tech and IDG Vulnerability Management, where such disclosures would not adversely impact the security of the technical infrastructure.
            * Where applicable, sharing best practice advice & instructions on remedial action for members.
        - (Current 9.8.10.b. becomes 9.8.10.c.)
        - 9.8.10.d. The Technical Officer must ensure the functioning of regular backups across the infrastructure.
        - 9.8.10.e. The Technical Officer must audit retention of services & data across the whole infrastructure at least once during the Executive cycle, with appropriate measures to backup and clean-up unused data and services.
        - 9.8.10.f. Data & services of third parties, such as members and other societies, shall be deemed "unused" if offline for more than 6 months, at the request of the relevant third party, or otherwise at the discretion of the Technical Officer. A backup of the data must be made available to the third party, following reasonable attempts to contact them, for a minimum of 7 days before completing clean-ups.
        - (See below for 9.8.10.g., currently 9.8.10.c.)
        - (Current 9.8.10.d. becomes 9.8.10.h.)

2. To amend currently 9.8.10.c., proposed 9.8.10.g., to the following:

    - The Technical Officer will disclose maintenance/outages of the technical infrastructure to members, subject to the following:
        - Planned maintenance at least 7 days ahead of commencing maintenance.

- Unplanned maintenance & outages at most 3 days after commencing of maintenance/outage - a brief interim status update is permissible.
- Completed maintenance and restoration of services, at most 3 days after completion.
- Where the outlined timelines cannot be met, all possible disclosures will be made in a timely manner, with relevant transparency to members to be made within the timelines as to why they cannot be met.
- For issues majorly impacting the functioning of the technical infrastructure or compromising its security, maintenance may proceed with less or no prior notice.
- Limitations may apply to whether a disclosure is made, and the extent of the disclosure, where such a disclosure is deemed to have an adverse impact on the security of the technical infrastructure.

3. For this and future Executive cycles to produce a proper Tech handover document for future Tech Officers, to bring much needed continuity to the role. Namely, this handover document should not be blank, and should contain informative, non-trivial information & guidance regarding the technical infrastructure, not unrelated things such as links to buy alcohol, Fruit Shoots, or M&Ms.

- *NB: this resolution is not a proposed amendment to the constitution.*